

OFFENSIVE WEB APPLICATION SECURITY WITH KALI & OWASP JUICE SHOP

Lab Environment Setup Guide

Building the Kali Linux VM · Installing OWASP Juice Shop · Configuring Burp Suite

 **IMPORTANT:** You may choose to deviate from the configuration below, but you will be responsible for troubleshooting any issues that arise. Docker and Vagrant are beyond the scope of this class.

Version: 1.0 · Last Updated: April 2026

Table of Contents

Table of Contents.....	2
Host Machine Requirements.....	3
VirtualBox VM Configuration.....	3
Operating System.....	4
Hardware.....	5
Hard Disk.....	6
Network.....	7
Kali Installation.....	8
Step 1 — Update the OS.....	9
Step 2 — Install Node.js.....	10
Step 3 — Install Juice Shop.....	11
Verify with Nmap.....	13
Configure Burp Suite.....	15
Burp Repeater.....	16
Burp Intruder.....	17
Accept the Cookie Consent.....	17
Sublime Text (Optional).....	18
Quick Reference — Key URLs.....	19
Snapshot Strategy.....	19

01

Virtualized Operating System

Setting up Kali Linux in VirtualBox

For this lab we will be utilizing Kali Linux as our attack platform. Download the Kali Linux **Installer Image** and **VirtualBox** from:

- <https://www.kali.org/get-kali/#kali-platforms>
- <https://www.virtualbox.org/wiki/Downloads>

Host Machine Requirements

Your host machine must be capable of provisioning a virtual machine with the following minimum specifications:

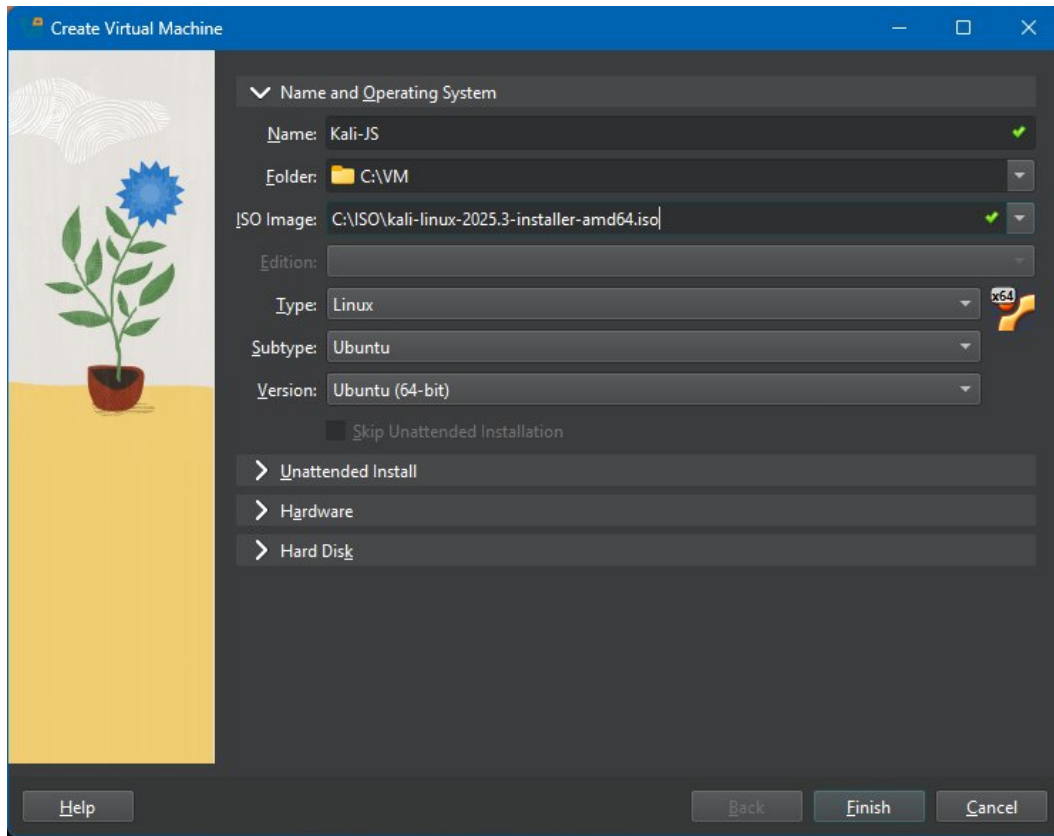
Resource	Minimum
RAM	4 GB minimum (8 GB recommended)
Disk Space	40 GB minimum (60 GB recommended)

VirtualBox VM Configuration

Create a new VM in VirtualBox. The screenshots below show the recommended settings for each configuration panel.

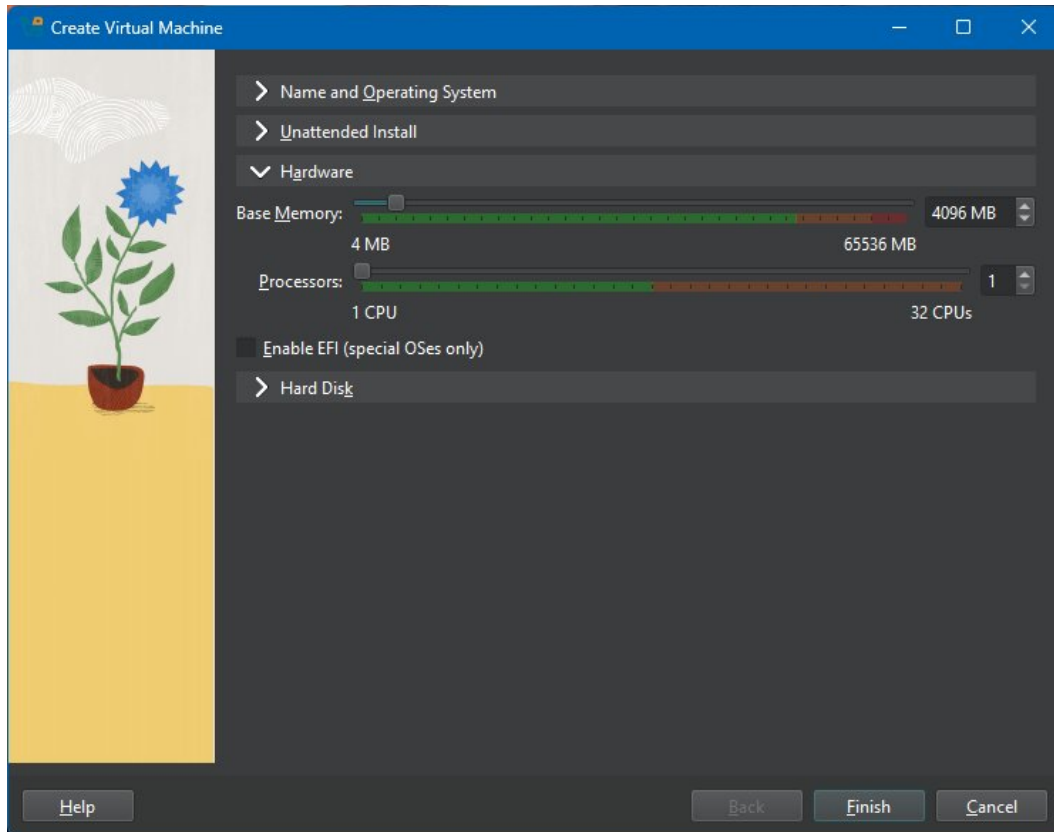
Operating System

Select Linux / Ubuntu (64-bit) and point the ISO Image to your downloaded Kali installer.



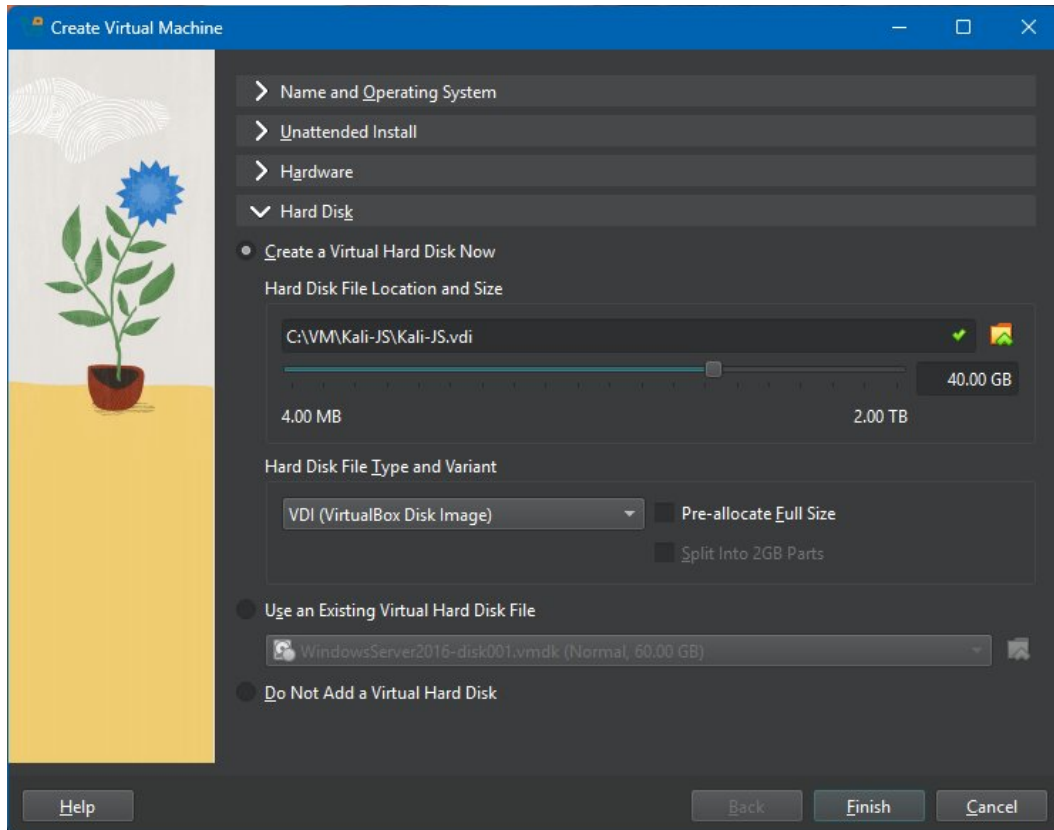
Hardware

Set Base Memory to 4096 MB (4 GB). You can allocate more if your host machine has sufficient RAM.



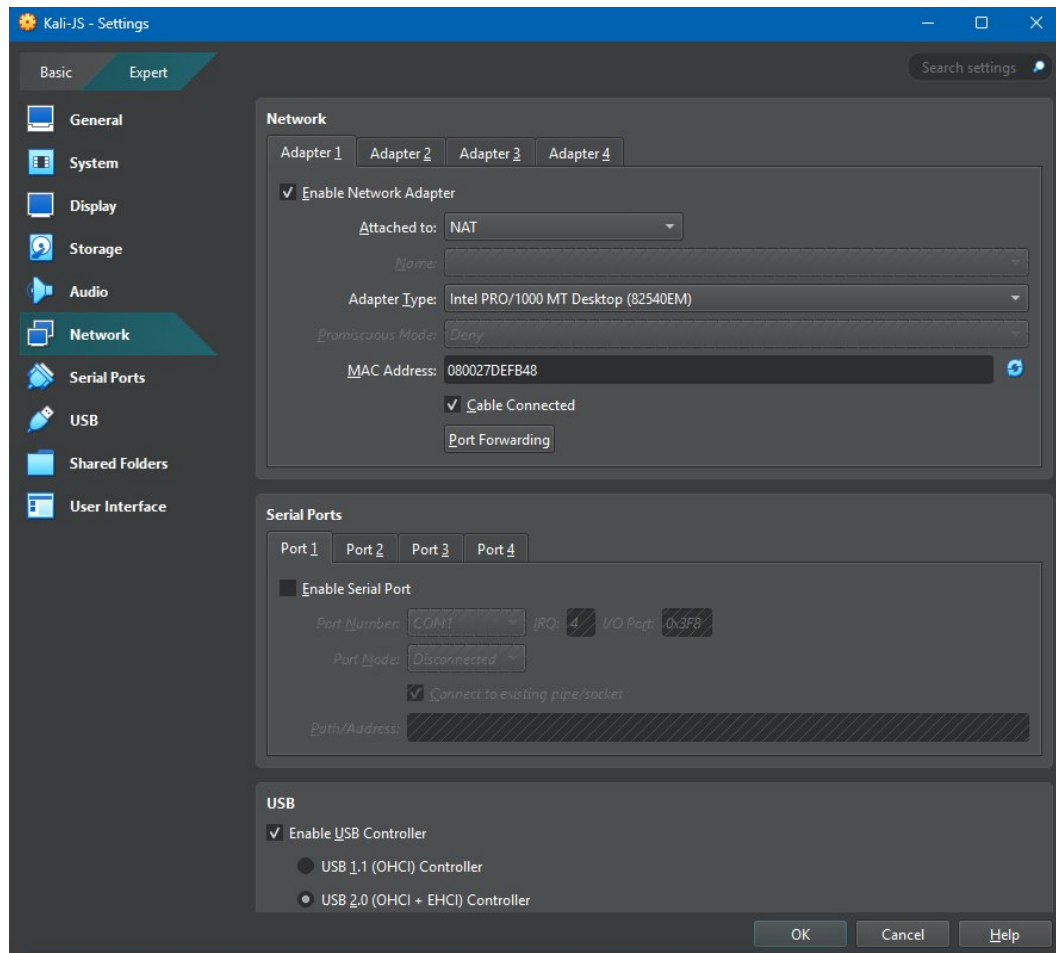
Hard Disk

Create a new virtual hard disk of at least 40 GB. Use the VDI format and dynamically allocated storage.



Network

Set the initial network adapter to **NAT**. Internet access is required during setup to update Kali and install Juice Shop. Once all setup is complete, it is strongly recommended to switch this to Host-Only to isolate the lab environment.



Kali Installation

Start the VM. Select Graphical installation when the boot menu appears. Use the settings below when prompted during setup:

Setting	Value
Hostname	kali
Domain	localhost
Username	student
Password	student (or your own – just remember it)
Partitioning Method	Guided – use entire disk
Disk Selection	Select the VM created virtual disk
Partition Scheme	All files in one partition
Write Changes	Yes
GRUB Boot Loader	Install on the device partition where Kali was installed

Once installation completes, reboot the machine and log in with the credentials you set above. Continue to the next section to update and configure Kali.

02

Configuring Kali

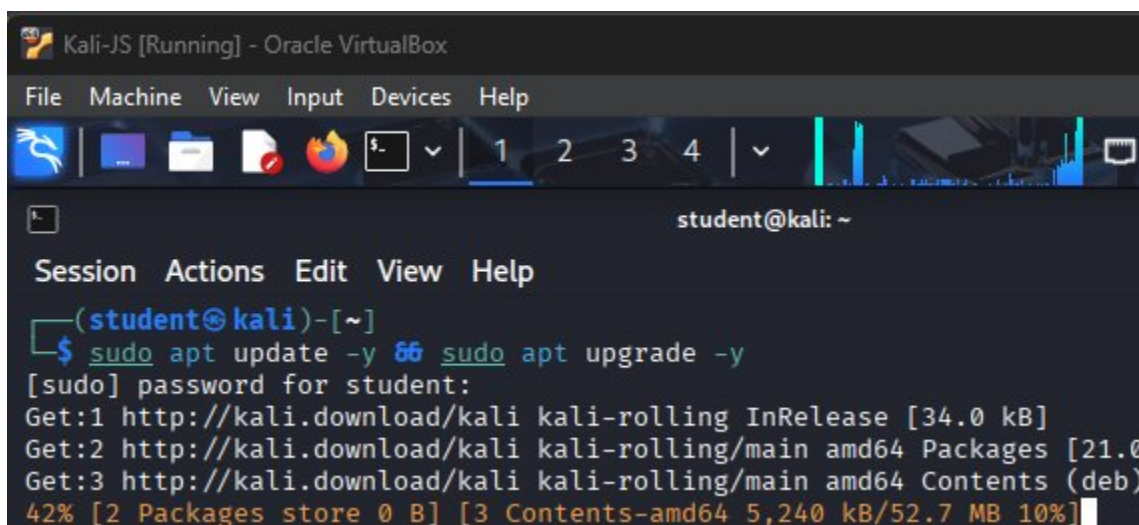
Updating the OS and installing required tools

From this point forward, all steps are performed inside the Kali virtual machine.

Step 1 — Update the OS

Open a terminal and run the following command to update and upgrade all packages. Enter your password when prompted.

```
sudo apt update -y && sudo apt upgrade -y
```

A screenshot of a Kali Linux terminal window titled 'Kali-JS [Running] - Oracle VirtualBox'. The terminal shows the execution of the command 'sudo apt update -y && sudo apt upgrade -y'. It prompts for the password for 'student', then shows the progress of updating package lists and upgrading packages. The output includes information about downloading InRelease, Packages, and Contents files from kali.download, and shows progress bars for the updates. The terminal window has a menu bar with 'File', 'Machine', 'View', 'Input', 'Devices', and 'Help'. The terminal prompt is 'student@kali: ~'.

The `-y` flag automatically answers yes to most prompts. If you see a screen that pauses for input (e.g. during the PostgreSQL upgrade), select the **default option** or answer **yes** and continue.

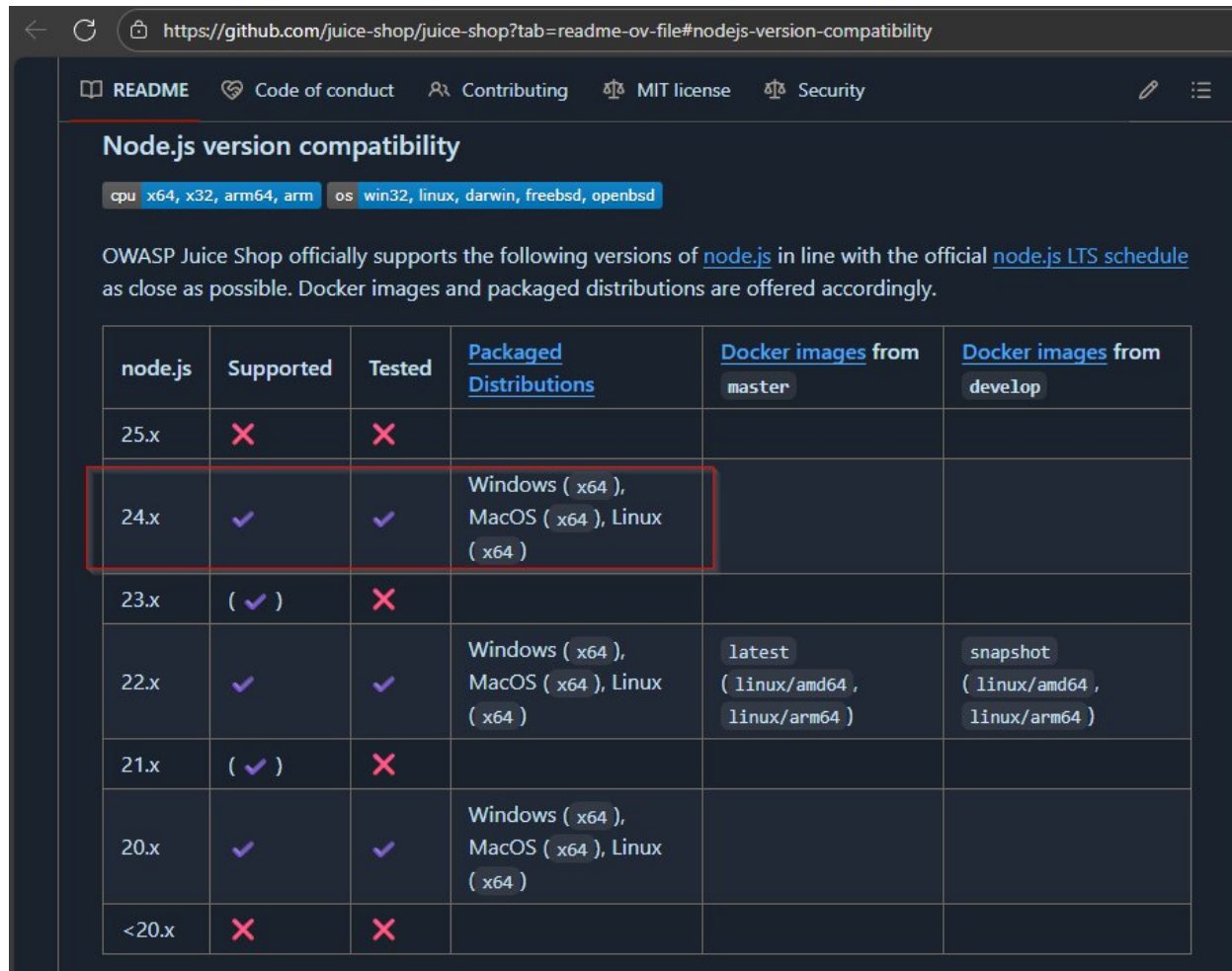
When the update completes, reboot the system:

```
sudo reboot now
```

📌 **RECOMMENDATION:** Create a VirtualBox snapshot at this point. Label it 'Post-Update Clean'. This gives you a known-good baseline to revert to if needed.

Step 2 — Install Node.js

OWASP Juice Shop requires a specific version of Node.js. Based on the Juice Shop compatibility table, we need Node.js 24.x.



Node.js version compatibility

cpu x64, x32, arm64, arm os win32, linux, darwin, freebsd, openbsd

OWASP Juice Shop officially supports the following versions of [node.js](#) in line with the official [node.js LTS schedule](#) as close as possible. Docker images and packaged distributions are offered accordingly.

node.js	Supported	Tested	Packaged Distributions	Docker images from master	Docker images from develop
25.x	✗	✗			
24.x	✓	✓	Windows (x64), MacOS (x64), Linux (x64)		
23.x	(✓)	✗			
22.x	✓	✓	Windows (x64), MacOS (x64), Linux (x64)	latest (linux/amd64 , linux/arm64)	snapshot (linux/amd64 , linux/arm64)
21.x	(✓)	✗			
20.x	✓	✓	Windows (x64), MacOS (x64), Linux (x64)		
<20.x	✗	✗			

Kali does not ship with the latest Node.js version. Add the NodeSource repository and install the LTS version with the following commands:

```
curl -fsSL https://deb.nodesource.com/setup_lts.x | sudo -E bash -  
sudo apt-get install -y nodejs
```

Verify the installed version — it should report v24.x or higher:

```
node -v
```

Step 3 — Install Juice Shop

With Node.js in place, you are ready to install OWASP Juice Shop. Open a terminal and note your current directory — the Juice Shop folder will be created here.

#	Step
1	Clone the Juice Shop repository: <code>git clone https://github.com/juice-shop/juice-shop.git --depth 1</code>
2	Move into the cloned folder: <code>cd juice-shop</code>
3	Install dependencies (only needed on first run or after source changes): <code>npm install</code>
4	Start Juice Shop: <code>npm start</code>

```
(student@kali)-[~]
$ pwd
/home/student

(student@kali)-[~]
$ git clone https://github.com/juice-shop/juice-shop.git --depth 1
Cloning into 'juice-shop' ...
remote: Enumerating objects: 1270, done.
remote: Counting objects: 100% (1270/1270), done.
remote: Compressing objects: 100% (867/867), done.
remote: Total 1270 (delta 380), reused 1262 (delta 380), pack-reused 0 (from 0)
Receiving objects: 100% (1270/1270), 46.02 MiB | 8.14 MiB/s, done.
Resolving deltas: 100% (380/380), done.

(student@kali)-[~]
$ cd juice-shop ; npm install && npm start
npm warn deprecated samsam@1.1.2: This package has been deprecated in favour of @sinonjs/samsam
npm warn deprecated formatio@1.1.1: This package is unmaintained. Use @sinonjs/formatio instead
npm warn deprecated @npmcli/move-file@1.1.2: This functionality has been moved to @npmcli/fs
npm warn deprecated inflight@1.0.6: This module is not supported, and leaks memory. Do not use it.
coalesce async requests by a key value, which is much more comprehensive and powerful.
npm warn deprecated eivindfjeldstad-dot@0.0.1: Use @eivifj/dot instead
```

You will see warnings about deprecated packages and vulnerabilities — **this is expected and intentional**. Juice Shop is a deliberately vulnerable application.

When startup is complete you will see: `info: Server listening on port 3000`. Minimize the terminal but **do NOT close it** — closing it will stop the server.

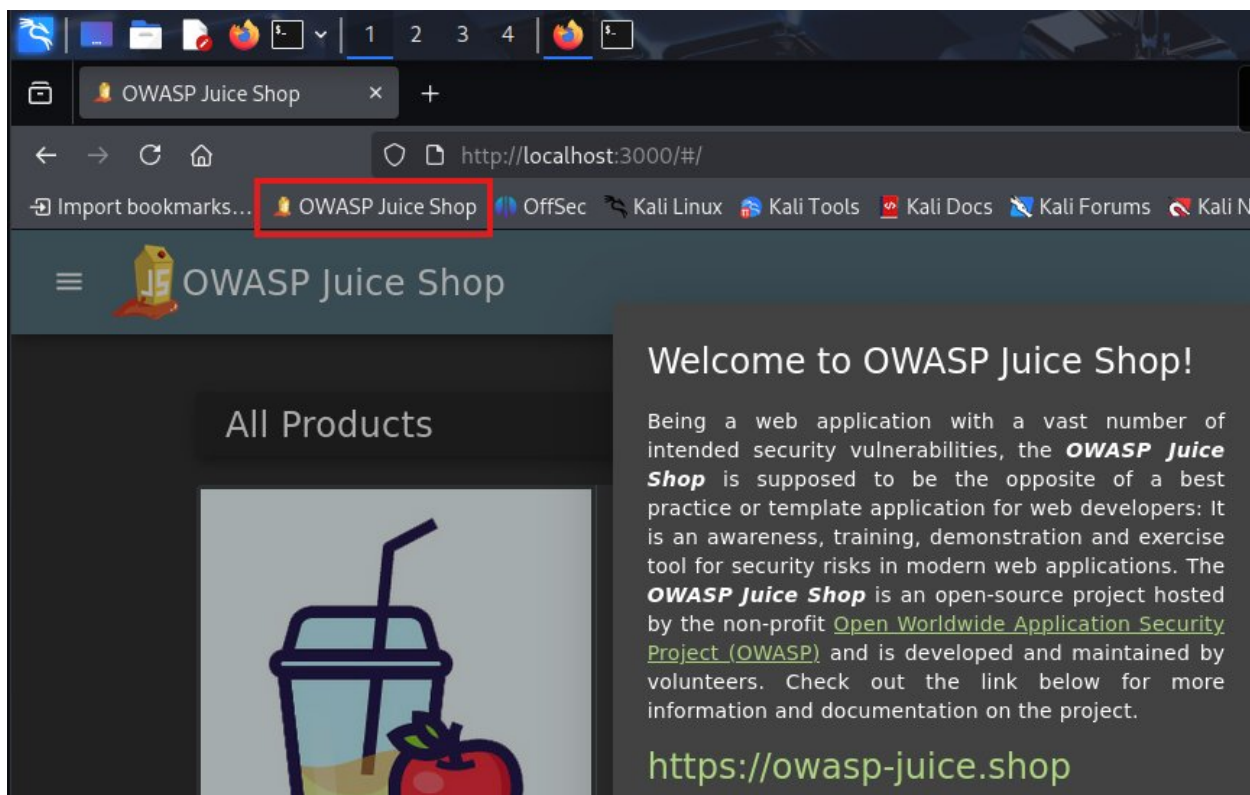
 **TIP:** Add the following alias to your `~/.zshrc` file to start Juice Shop with a single command: `alias juicy='cd ~/juice-shop ; npm start'`

TIP: To run Juice Shop without keeping a terminal open, use a terminal multiplexer like TMUX: run `tmux`, start Juice Shop, then detach with `Ctrl+B` followed by `D`.

With Juice Shop running, open the browser and navigate to:

<http://localhost:3000>

Bookmark this URL for quick access throughout the course. You should see the Juice Shop welcome page:



RECOMMENDATION: Before starting any lab work, shut down the VM and create a second snapshot labelled 'Juice Shop Ready'. Use this to reset to a clean state at any point during training.

03

Verifying the Environment

Confirming Juice Shop is reachable and Burp Suite is ready

Before beginning any lab exercises, take a few minutes to confirm your environment is correctly configured. The checks below will catch the most common setup issues.

Verify with Nmap

Run a quick nmap service scan against localhost to confirm Juice Shop is listening on port 3000:

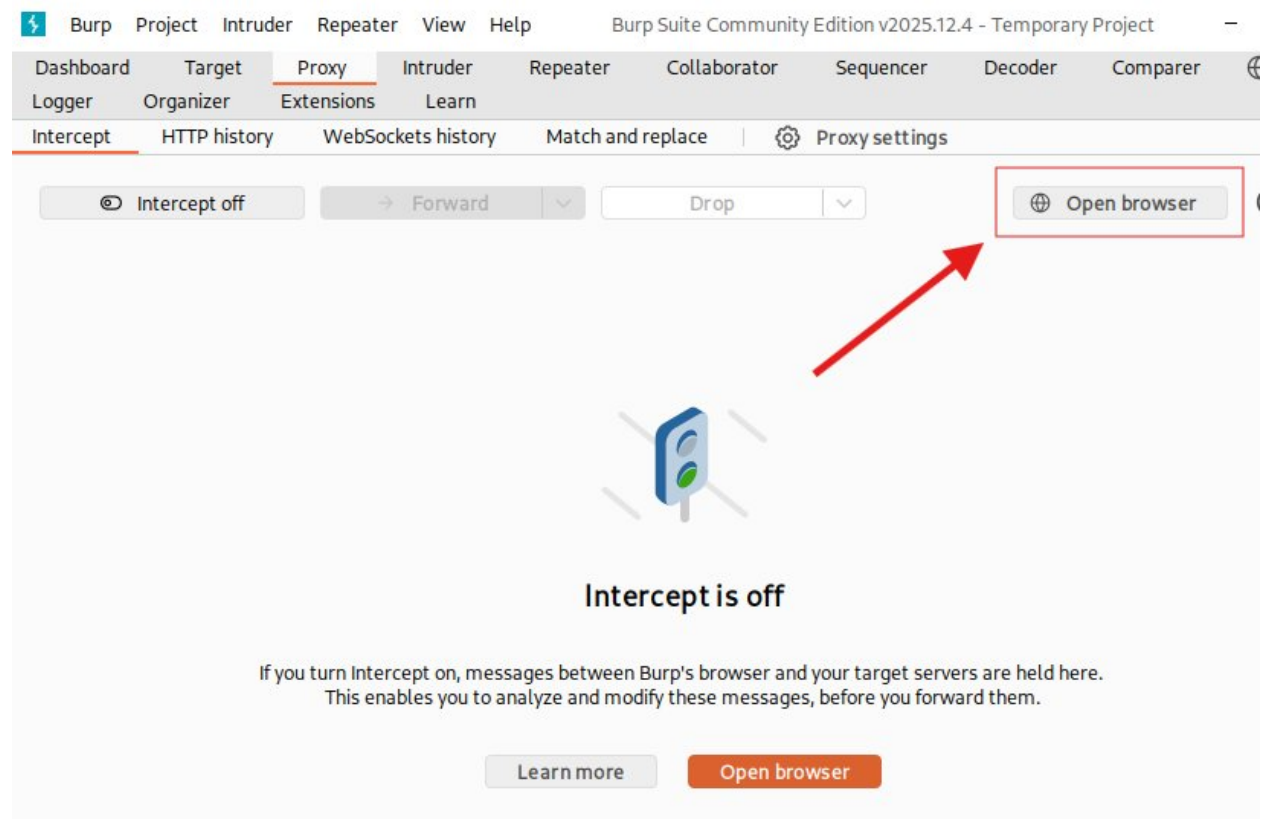
```
sudo nmap -sV -sC -p- 127.0.0.1
```

You should see port 3000/tcp open in the output. The screenshot below shows a successful scan, including the Juice Shop HTTP response headers and the Access-Control-Allow-Methods header confirming the available HTTP methods.


```
(student@kali)-[~]
$ sudo nmap -sV -sC -p- 127.0.0.1
Starting Nmap 7.98 ( https://nmap.org ) at 2026-01-31 14:14 -0500
Nmap scan report for localhost (127.0.0.1)
Host is up (0.0000010s latency).
Not shown: 65534 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
3000/tcp  open  ppp?
| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 200 OK
|     Access-Control-Allow-Origin: *
|     X-Content-Type-Options: nosniff
|     X-Frame-Options: SAMEORIGIN
|     Feature-Policy: payment 'self'
|     X-Recruiting: /#/jobs
|     Accept-Ranges: bytes
|     Cache-Control: public, max-age=0
|     Last-Modified: Sat, 31 Jan 2026 19:10:10 GMT
|     ETag: W/"1252f-19c1576755a"
|     Content-Type: text/html; charset=UTF-8
|     Content-Length: 75055
|     Vary: Accept-Encoding
|     Date: Sat, 31 Jan 2026 19:14:27 GMT
|     Connection: close
|   <—
|   Copyright (c) 2014-2026 Bjoern Kimminich & the OWASP Juice Shop contributors.
|   SPDX-License-Identifier: MIT
|   <!doctype html>
|   <html lang="en" data-beasties-container>
|   <head>
|   <meta charset="utf-8">
|   <title>OWASP Juice Shop</title>
|   <meta name="description" content="Probably the most modern and sophisticated insecure web application">
|   <meta name="viewport" content="width=device-width, initial-scale=1">
|   <link id="favicon" rel="icon"
|   HTTPOptions, RTSPRequest:
|   HTTP/1.1 204 No Content
|   Access-Control-Allow-Origin: *
|   Access-Control-Allow-Methods: GET,HEAD,PUT,PATCH,POST,DELETE
|   Vary: Access-Control-Request-Headers
|   Content-Length: 0
|   Date: Sat, 31 Jan 2026 19:14:27 GMT
|   Connection: close
|   Help, NCP:
|   HTTP/1.1 400 Bad Request
|_  Connection: close
```

Configure Burp Suite

Burp Suite is your primary proxy tool throughout this training. Launch it from the Kali applications menu or terminal. Use the Proxy tab's built-in browser for the simplest setup — no manual proxy configuration needed.



Click **Open browser** in the Proxy > Intercept panel (highlighted with the arrow above). This opens a Chromium instance pre-configured to route all traffic through Burp's proxy at 127.0.0.1:8080.

Burp Repeater

Repeater allows you to capture a request, modify it, and replay it as many times as needed. You will use this for most of the injection and manipulation exercises.

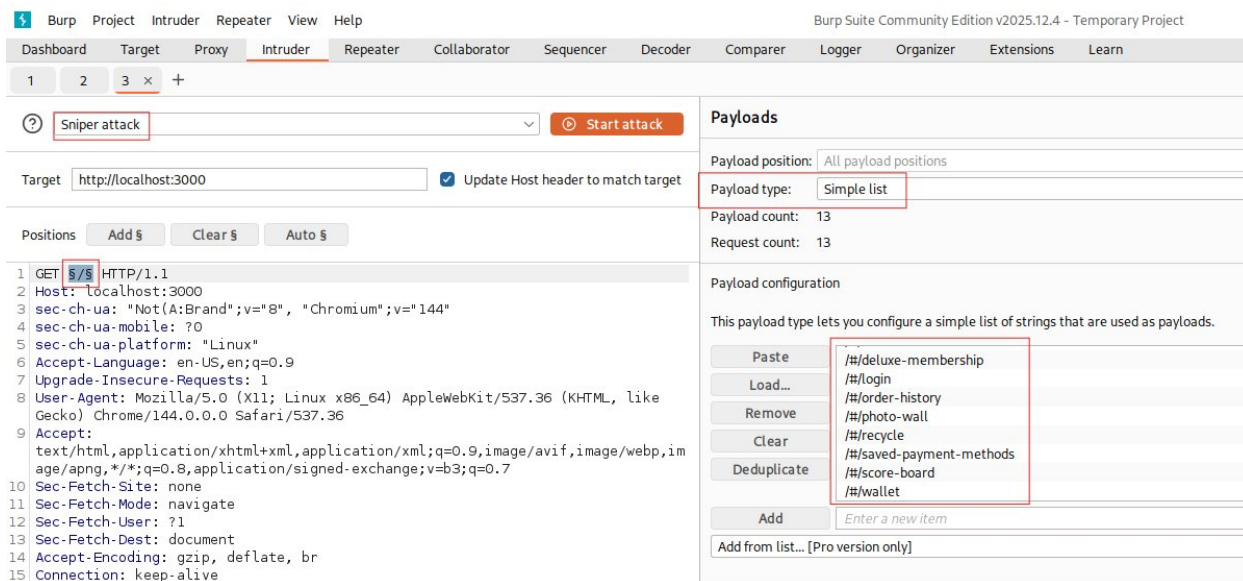
The screenshot displays the Burp Suite Repeater interface. The top menu bar includes options like Burp, Project, Intruder, Repeater, View, and Help. Below the menu is a toolbar with buttons for Send, Cancel, and navigation. The main area is divided into two panels: Request and Response.

Request Panel: Shows a captured HTTP GET request to localhost:3000. The request includes various headers such as 'sec-ch-ua', 'Accept-Language', 'User-Agent', and 'Connection: keep-alive'.

Response Panel: Shows the HTML response from the server. It includes a title 'OWASP Juice Shop', a description, and several scripts loaded from Cloudflare. The response is rendered in a pretty-printed format.

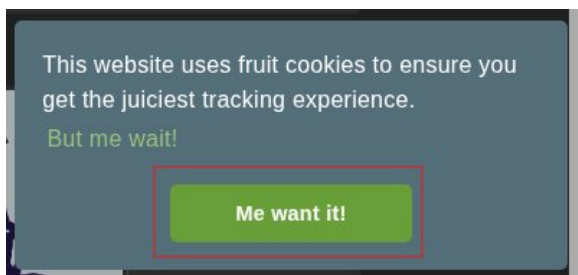
Burp Intruder

Intruder automates sending modified requests using payload lists. The screenshot below shows a Sniper attack configured against the Juice Shop with a list of known Angular routes as payloads — useful for hidden endpoint enumeration.



Accept the Cookie Consent

When you first open Juice Shop, you will be prompted to accept cookies. Click “Me want it!” to dismiss the banner. This is also your first Juice Shop challenge — accepting cookies completes a 1-star challenge on the Score Board.



TIP: If the cookie banner does not appear, try opening Juice Shop in a fresh private/incognito browser window.

04

Additional Notes

Optional tools and useful references

Sublime Text (Optional)

During the training sessions the instructor will be using Sublime Text as a code and note editor. It provides excellent syntax highlighting for HTML, JavaScript, and JSON — all formats you will encounter while testing Juice Shop.

Installation instructions for Kali Linux are available at:

https://www.sublimetext.com/docs/linux_repositories.html

 **TIP:** Sublime Text is optional — any text editor works. VS Code and gedit are also available on Kali and either is perfectly suitable.

Quick Reference — Key URLs

Resource	URL
OWASP Juice Shop	http://localhost:3000 / http://127.0.0.1:3000
Juice Shop GitHub	https://github.com/juice-shop/juice-shop
Get Kali Linux	https://www.kali.org/get-kali/#kali-platforms
NodeSource (Node.js)	https://deb.nodesource.com
Burp Suite Community	https://portswigger.net/burp/communitydownload
Sublime Text (Linux)	https://www.sublimetext.com/docs/linux_repositories.html

Snapshot Strategy

Snapshots are your best friend during this training. The recommended snapshot points are:

Snapshot Name	When to Take It
Post-Update Clean	After OS update/upgrade, before any software installation
Juice Shop Ready	After Juice Shop installed and confirmed working — your main training baseline
Pre-Lab [N]	Optional: before starting each lab if you want per-lab restore points